

1 Preface

1.1 The technology landscape of the financial sector is transforming at a rapid pace and the underlying information technology (IT) infrastructure supporting financial services has grown in scope and complexity in recent years. Many financial institutions (FIs) are riding the wave of digitalisation to increase operational efficiency and to deliver better services to consumers.

1.2 Digital transformation in the financial sector can be broadly characterised by the adoption of new technology and the use of existing technology in innovative ways to achieve greater automation and enrich financial service offerings.

1.3 While digital transformation brings significant benefits to the financial ecosystem, it also increases FIs' exposure to a range of technology risks, including cyber risk. The techniques used by cyber threat actors are becoming increasingly sophisticated, and weak links in the interconnected financial ecosystem can be compromised to carry out fraudulent financial transactions, exfiltrate sensitive financial data or disrupt IT systems that support financial services. Hence, each FI should seek to understand their exposure to technology risks and put in place a robust risk management framework to ensure IT and cyber resilience.

1.4 The revised MAS Technology Risk Management Guidelines set out technology risk management principles and best practices for the financial sector, to guide FIs in the following:

(a) **Establish Sound and Robust Technology Risk Governance and Oversight**

The board of directors and senior management at an FI play an integral part in the oversight and management of technology risk. The board of directors and senior management should cultivate a strong risk culture, and ensure the establishment of a sound and robust technology risk management framework.

(b) **Maintain Cyber Resilience**

Strong cyber resilience is critical for sustaining trust and confidence in financial services. FIs should adopt a defence-in-depth approach to strengthening cyber resilience. It is also important that FIs establish and continuously improve their IT processes and controls to preserve confidentiality, integrity and availability of data and IT systems.

2 Application of the MAS Technology Risk Management Guidelines

2.1 The aim of the MAS Technology Risk Management Guidelines (hereafter referred as “the Guidelines”) is to promote the adoption of sound and robust practices for the management of technology risk.

2.2 The Guidelines do not affect, and should not be regarded as a statement of the standard of care owed by FIs to their customers. The extent and degree to which an FI implements the Guidelines should be commensurate with the level of risk and complexity of the financial services offered and the technologies supporting such services. In supervising an FI, the degree of observance with the spirit of the Guidelines by an FI is an area of consideration by MAS.

2.3 These Guidelines provide general guidance, and are not intended to be comprehensive nor replace or override any legislative provisions. They should be read in conjunction with the provisions of the relevant legislation, the subsidiary legislation made under the relevant legislation, as well as written directions, notices, codes and other guidelines that MAS may issue from time to time pursuant to the relevant legislation and subsidiary legislation.

3 Technology Risk Governance and Oversight

3.1 Role of the Board of Directors and Senior Management

3.1.1 Technology is a key business enabler in the financial sector and FIs rely on technology to deliver financial services. It is vital that the FI's board of directors and senior management ensure effective internal controls and risk management practices are implemented to achieve security, reliability and resilience of its IT operating environment.

3.1.2 Both the board of directors and senior management should have members with the knowledge to understand and manage technology risks, which include risks posed by cyber threats.

3.1.3 The board of directors and senior management should ensure a Chief Information Officer, Chief Technology Officer or Head of IT, and a Chief Information Security Officer or Head of Information Security¹, with the requisite expertise and experience, are appointed. The appointments should be minimally approved by the Chief Executive Officer.

3.1.4 The board of directors and senior management should ensure a technology risk management strategy is established and implemented.

3.1.5 The board of directors and senior management should ensure key IT decisions are made in accordance with the FI's risk appetite.

3.1.6 Given that technology underpins many of the operations and services offered by an FI, the board of directors and senior management should set the tone from the top and cultivate a strong culture of technology risk awareness and management at all levels of staff within the FI.

¹

"chief information officer", "chief technology officer", or "head of information technology", who is principally responsible for establishing and implementing the overall information technology strategy, overseeing the day-to-day information technology operations, and managing the information technology risks of the financial institution.

"chief information security officer" or "head of information security", who is principally responsible for the information security strategy and programme of the financial institution, including but not limited to information security policies and procedures to safeguard information assets, information security controls, and the management of information security.

- *Guidelines on Individual Accountability and Conduct, Annex B*

3.1.7 The board of directors or a committee delegated by it, is responsible for:

- (a) ensuring a sound and robust risk management framework is established and maintained to manage technology risks;
- (b) ensuring there is a technology risk management function to oversee the technology risk management framework and strategy, as well as to provide an independent view of the technology risks faced by the FI;
- (c) giving senior executives, who are responsible for executing the FI's technology risk management strategy, sufficient authority, resources and access to the board of directors;
- (d) approving the risk appetite and risk tolerance statement that articulates the nature and extent of technology risks that the FI is willing and able to assume;
- (e) undertaking regular reviews of the technology risk management strategy for continued relevance;
- (f) assessing management competencies for managing technology risks; and
- (g) ensuring an independent audit function is established to assess the effectiveness of controls, risk management and governance of the FI.

3.1.8 Senior management is responsible for:

- (a) establishing the technology risk management framework and strategy;
- (b) managing technology risks based on the established framework and strategy;
- (c) ensuring sound and prudent policies, standards and procedures for managing technology risks are established and maintained, and that standards and procedures are implemented effectively;

-
- (d) ensuring the roles and responsibilities² of staff in managing technology risks are delineated clearly; and
 - (e) apprising the board of directors of salient and adverse technology risk developments and incidents that are likely to have a major impact on the FI in a timely manner.

3.2 Policies, Standards and Procedures

3.2.1 The FI should establish policies, standards and procedures and, where appropriate, incorporate industry standards and best practices to manage technology risks and safeguard information assets³ in the FI. The policies, standards and procedures should also be regularly reviewed and updated, taking into consideration the evolving technology and cyber threat landscape.

3.2.2 The FI should ensure risks associated with deviations are thoroughly reviewed and assessed. The risk assessment should be approved by senior management. Approved deviations should be reviewed periodically to ensure the residual risks remain at an acceptable level.

3.2.3 Compliance processes should be implemented to verify that policies, standards and procedures are adhered to. These include follow-up processes for non-compliance.

3.3 Management of Information Assets

3.3.1 To have an accurate and complete view of its IT operating environment, the FI should establish information asset management practices that include the following:

- (a) identification of information assets that support the FI's business and delivery of financial services;

² The roles and responsibilities of senior management and staff could be defined and tracked using a Responsibility Assignment Matrix, also known as RACI. The RACI matrix outlines who are responsible and accountable for the functions, as well as who should be consulted or informed.

³ Information assets include data, hardware and software. Information assets are not limited to those that are owned by the FI. They also include those that are entrusted to the FI by customers or third parties, rented or leased by the FI, and those that are used by service providers to deliver their services to the FI. Adapted from CPMI-IOSCO, *Guidance on Cyber Resilience for Financial Market Infrastructures*, June 2016.

- (b) classification of an information asset based on its security classification or criticality;
- (c) ownership of information assets, and the roles and responsibilities of the staff managing the information assets; and
- (d) establishment of policies, standards and procedures to manage information assets according to their security classification or criticality.

3.3.2 The FI should maintain an inventory of all its information assets. The inventory should be reviewed periodically and updated whenever there are changes.

3.4 Management of Third Party Services

3.4.1 The use of certain third party services by FIs may not always constitute outsourcing. However, as many of these services are provisioned or delivered using IT, or may involve confidential or sensitive customer information being stored or processed electronically by the third party, the FI's operations and its customers may be adversely impacted if there is a system failure or security breach at the third party.

3.4.2 The FI should assess and manage its exposure to technology risks that may affect the confidentiality, integrity and availability of the IT systems and data at the third party before entering into a contractual agreement or partnership.

3.4.3 On an ongoing basis, the FI should ensure the third party employs a high standard of care and diligence in protecting data confidentiality⁴ and integrity as well as ensuring system resilience.

3.5 Competency and Background Review

3.5.1 As the human element plays an important role in managing IT systems and processes in an IT environment, the FI should ensure personnel, including contractors and service providers, have the requisite level of competence and skills to perform the IT functions and manage technology risks.

⁴ Data confidentiality refers to the protection of sensitive or confidential data such as customer details from unauthorised access and disclosure.

3.5.2 Insider threat, which includes theft of confidential data, sabotage of IT systems and fraud by staff, contractors and service providers, is considered one of the risks to an organisation. A background check on personnel, who has access to the FI's data and IT systems, should be performed to minimise this risk.

3.6 Security Awareness and Training

3.6.1 A comprehensive IT security awareness training programme should be established to maintain a high level of awareness among all staff in the FI. The content of the training programme should minimally include information on the prevailing cyber threat landscape and its implications, the FI's IT security policies and standards, as well as an individual's responsibility to safeguard information assets. All personnel in the FI should be made aware of the applicable laws, regulations, and guidelines pertaining to the use of, and access to, information assets.

3.6.2 The training programme should be conducted at least annually for all staff, contractors and service providers who have access to the FI's information assets.

3.6.3 The board of directors should undergo training to raise their awareness on risks associated with the use of technology and enhance their understanding of technology risk management practices.

3.6.4 The training programme should be reviewed periodically to ensure its contents remain current and relevant. The review should take into consideration changes in the FI's IT security policies, prevalent and emerging risks, and the evolving cyber threat landscape.

4 Technology Risk Management Framework

4.1 Risk Management Framework

4.1.1 The FI should establish a risk management framework to manage technology risks. Appropriate governance structures and processes should be established, with well-defined roles, responsibilities, and clear reporting lines across the various organisational functions.

4.1.2 Effective risk management practices and internal controls should be instituted to achieve data confidentiality and integrity, system security and reliability, as well as stability and resilience in its IT operating environment.

4.1.3 The risk owner, who is accountable for ensuring proper risk treatment measures are implemented and enforced for a specific technology risk, should be identified. The role of the risk owner may be assumed by a function or group of functions within the FI, who is given the authority to manage technology risks.

4.1.4 The framework should also encompass the following components:

- (a) risk identification – identify threats and vulnerabilities to the FI and information assets;
- (b) risk assessment – assess the potential impact and likelihood of threats and vulnerabilities to the FI and information assets;
- (c) risk treatment – implement processes and controls to manage technology risks posed to the FI and protect the confidentiality, integrity and availability of information assets; and
- (d) risk monitoring, review and reporting – monitor and review technology risks, which include risks that customers are exposed to, changes in business strategy, IT systems, environmental or operating conditions; and report key risks to the board of directors and senior management.

4.1.5 As business and IT environments, as well as the cyber threat landscape, tend to evolve over time, the FI should review the adequacy and effectiveness of its risk management framework regularly.

4.2 Risk Identification

4.2.1 The FI should identify the threats and vulnerabilities applicable to its IT environment, including information assets that are maintained or supported by third party service providers. Examples of security threats that could have a severe impact on the FI and its stakeholders include internal sabotage, malware and data theft.

4.3 Risk Assessment

4.3.1 The FI should perform an analysis of the potential impact and consequences of the threats and vulnerabilities on the overall business and operations. The FI should take into consideration financial, operational, legal, reputational and regulatory factors in assessing technology risks.

4.3.2 To facilitate the prioritisation of technology risks, a set of criteria measuring and determining the likelihood and impact of the risk scenarios should be established.

4.4 Risk Treatment

4.4.1 The FI should develop and implement risk mitigation and control measures that are consistent with the criticality of the information assets and the level of risk tolerance. The IT control and risk mitigation approach should be subject to regular review and update, taking into account the changing threat landscape and variations in the FI's risk profile.

4.4.2 As there are residual risks from threats and vulnerabilities which cannot be fully eliminated, the FI should assess whether risks have been reduced to an acceptable level after applying the mitigating measures. The criteria and approving authorities for risk acceptance should be clearly defined and it should be commensurate with the FI's risk tolerance.

4.4.3 The FI should take insurance cover for various insurable technology risks to reduce financial impact such as recovery and restitution costs.

4.5 Risk Monitoring, Review and Reporting

4.5.1 The FI should institute a process for assessing and monitoring the design and operating effectiveness of IT controls against identified risks.

4.5.2 A risk register should be maintained to facilitate the monitoring and reporting of technology risks. Significant risks should be monitored closely and reported to the board of directors and senior management. The frequency of monitoring and reporting should be commensurate with the level of risk.

4.5.3 To facilitate risk reporting to management, technology risk metrics should be developed to highlight information assets that have the highest risk exposure. In determining the technology risk metrics, the FI should take into account risk events and audit observations, as well as applicable regulatory requirements.

5 IT Project Management and Security-by-Design

5.1 Project Management Framework

5.1.1 A project management framework should be established to ensure consistency in project management practices, and delivery of outcomes that meets project objectives and requirements. The framework should cover the policies, standards, procedures, processes and activities to manage projects from initiation to closure.

5.1.2 Detailed IT project plans should be established for all IT projects. An IT project plan should set out the scope of the project, as well as the activities, milestones and the deliverables to be realised at each phase of the project. The roles and responsibilities of staff involved in the project should be clearly defined in the plan.

5.1.3 Key documentation in the IT project life cycle, including the feasibility analysis, cost-benefit analysis, business case analysis, project plan, as well as the implementation plan, should be maintained and approved by the relevant business and IT management.

5.1.4 As project risks can adversely impact the IT project delivery timeline, budget and quality of the project deliverables, a risk management process should be established to identify, assess, treat and monitor the attendant risks throughout the project life cycle.

5.2 Project Steering Committee

5.2.1 For large and complex projects that impact the business, a project steering committee consisting of key stakeholders, including business owners and IT, should be formed to provide direction, guidance and oversight to ensure milestones are reached, and deliverables are realised in a timely manner.

5.2.2 Risks and issues for large and complex projects, which cannot be resolved at the project management level, should be escalated to the project steering committee and senior management.

5.3 System Acquisition

5.3.1 The FI should establish standards and procedures for vendor evaluation and selection to ensure the selected vendor is qualified and able to meet its project requirements and deliverables. The level of assessment and due diligence performed should be commensurate with the criticality of the project deliverables to the FI.

5.3.2 It is important that the FI assesses the robustness of the vendor's software development and quality assurance practices, and ensures stringent security practices are in place to safeguard and protect any sensitive data the vendor has access to over the course of the project. Any vendor access to the FI's IT systems should be controlled and monitored.

5.3.3 If a project involves a commercial off-the-shelf (COTS) solution that does not meet the FI's security requirements, the FI should assess the risks and ensure adequate mitigating controls are implemented to address the risks before the solution is deployed.

5.3.4 The FI should assess if a source code escrow agreement should be in place, based on the criticality of the acquired software to the FI's business, so that the FI can have access to the source code in the event that the vendor is unable to support the FI. Suitable alternatives to replace the software should be identified if an escrow agreement could not be implemented.

5.4 System Development Life Cycle and Security-By-Design

5.4.1 The FI should establish a framework to manage its system development life cycle (SDLC).⁵ The framework⁶ should clearly define the processes, procedures and controls in each phase of the life cycle, such as initiation/planning, requirements analysis, design, implementation, testing and acceptance. Standards and procedures for the different phases of the SDLC should be maintained.

5.4.2 The security-by-design approach refers to building security in every phase of the SDLC in order to minimise system vulnerabilities and reduce the attack surface. The FI should incorporate security specifications in the system design, perform continuous security evaluation, and adhere to security practices throughout the SDLC.

5.4.3 Security requirements should minimally cover key control areas such as access control, authentication, authorisation, data integrity and confidentiality, system activity logging, security event tracking and exception handling.

⁵ The overall process of developing/acquiring and managing systems from initiation/planning, requirements gathering, design, implementation, testing, deployment and maintenance to disposal.

⁶ Within the SDLC framework, it includes models or methodologies such as Waterfall and Agile.

5.4.4 The SDLC should, where relevant, involve the IT security function in each phase of the life cycle.

5.5 System Requirements Analysis

5.5.1 The FI should identify, define and document the functional requirements for the IT system. In addition to functional requirements, key requirements such as system performance, resilience and security controls, should also be established and documented.

5.5.2 In establishing the security requirements, the FI should assess the potential threats and risks related to the IT system, and determine the acceptable level of security required to meet its business needs.

5.6 System Design and Implementation

5.6.1 As part of the design phase, the FI should review the proposed architecture and design of the IT system, including the IT controls to be built into the system, to ensure they meet the defined requirements, before implementation.

5.6.2 The FI should verify that system requirements are met by the current system design and implementation. Any changes to, or deviations from, the defined requirements should be endorsed by relevant stakeholders.

5.6.3 Relevant domain experts should be engaged to participate in the design review. For example, the security design and architecture of the IT system should be reviewed by IT security specialists or qualified security consultants.

5.7 System Testing and Acceptance

5.7.1 A methodology for system testing⁷ should be established. The scope of testing should cover business logic, system function, security controls and system performance under various load and stress conditions. A test plan should be established and approved before testing.

⁷ System testing includes unit, modular, integration, system and user acceptance testing.

5.7.2 The FI should trace the requirements during the testing phase, and ensure each requirement is covered by appropriate test cases.

5.7.3 The FI should maintain separate physical or logical environments for unit, system integration and user acceptance testing, and restrict access to each environment on a need-to basis.

5.7.4 The FI should perform regression testing for changes (e.g. enhancement, rectification, etc.) to an existing IT system to validate that it continues to function properly after the changes have been implemented.

5.7.5 Issues identified from testing, including system defects or software bugs, should be properly tracked and addressed. Major issues that could have an adverse impact on the FI's operations or delivery of service to customers should be reported to the project steering committee and addressed prior to deployment to the production environment.

5.7.6 The FI should ensure the results of all testing that was conducted are documented in the test report, and signed off by the relevant stakeholders.

5.8 Quality Management

5.8.1 During project planning, the FI should define the expected quality attributes and the assessment metrics for the project deliverables based on its quality control standards.

5.8.2 Quality assurance should be performed by an independent quality assurance function to ensure project activities and deliverables comply with the FI's policies, procedures and standards.

6 Software Application Development and Management

6.1 Secure Coding, Source Code Review and Application Security Testing

6.1.1 Software bugs or vulnerabilities are typically targeted and exploited by threat actors to compromise an IT system, and they often occur because of poor software development practices. To minimise the bugs and vulnerabilities in its software, the FI should adopt standards on secure coding, source code review⁸ and application security testing.

6.1.2 The secure coding and source code review standards should cover areas such as secure programming practices, input validation, output encoding, access controls, authentication, cryptographic practices, and error and exception handling.

6.1.3 A policy and procedure on the use of third party and open-source software codes should be established to ensure these codes are subject to review and testing before they are integrated into the FI's software.

6.1.4 To facilitate the remediation of vulnerabilities in a timely manner, the FI should keep track of updates and reported vulnerabilities for third party and open-source software codes that are incorporated in the FI's software.

6.1.5 The FI should ensure its software developers are trained or have the necessary knowledge and skills to apply the secure coding and application security standards when developing applications.

6.1.6 It is essential for the FI to establish a comprehensive strategy to perform application security validation and testing. The FI may use a mixture of static, dynamic and interactive application security testing methods (refer to Annex A on Application Security Testing) to validate the security of the software application. The software validation and testing rules should be reviewed periodically and kept current.

⁸ Source code review is a systematic and methodical examination of the source code of an application, with the objective of finding coding errors, poor coding practices or other software defects.

6.1.7 All issues and software defects discovered from the source code review and application security testing should be tracked. Major issues and software defects should be remediated before production deployment.

6.2 Agile Software Development

6.2.1 Agile software development is based on an iterative and incremental development model to accelerate software development and delivery to respond to business and customer needs. When adopting Agile software development methods, the FI should continue to incorporate the necessary SDLC and security-by-design principles throughout its Agile process.

6.2.2 The FI should ensure secure coding, source code review and application security testing standards are applied during Agile software development.

6.3 DevSecOps Management

6.3.1 DevSecOps is the practice of automating and integrating IT operations, quality assurance and security practices in the software development process. It constitutes continuous integration, continuous delivery and IT security practices for frequent, efficient, reliable and secure development, testing and release of software products. The FI should ensure its DevSecOps activities and processes are aligned with its SDLC framework and IT service management processes (e.g. configuration management, change management, software release management).

6.3.2 The FI should implement adequate security measures and enforce segregation of duties for the software development, testing and release functions in its DevSecOps processes.

6.4 Application Programming Interface Development

6.4.1 Application programming interfaces (APIs)⁹ enable various software applications to communicate and interact with each other and exchange data. Open APIs are publicly available APIs that provide developers with programmatic access to a software application or web service. FIs may collaborate with FinTech companies and develop open APIs, which

⁹ APIs are sets of protocols that define how one application interacts with another, usually to facilitate an information exchange.

are used by third parties to implement products and services for customers and the marketplace. Hence, it is important for the FI to establish adequate safeguards to manage the development and provisioning of APIs for secure delivery of such services.

6.4.2 A well-defined vetting process should be implemented for assessing third parties' suitability in connecting to the FI via APIs, as well as governing third party API access. The vetting criteria should take into account factors such as the third party's nature of business, cyber security posture, industry reputation and track record.

6.4.3 The FI should perform a risk assessment before allowing third parties to connect to its IT systems via APIs, and ensure the implementation for each API is commensurate with the sensitivity and business criticality of the data being exchanged, and the confidentiality and integrity requirements of the data.

6.4.4 Security standards for designing and developing secure APIs should be established. The standards should include the measures to protect the API keys or access tokens,¹⁰ which are used to authorise access to APIs to exchange confidential data. A reasonable timeframe should be defined and enforced for access token expiry to reduce the risk of unauthorised access.

6.4.5 Strong encryption standards and key management controls should be adopted to secure transmission of sensitive data through APIs.

6.4.6 A robust security screening and testing of the API should be performed between the FI and its third parties before it is deployed into production. The FI should log the access sessions by third parties, such as the identity of the party making the API connections, date and time, as well as the data being accessed.

6.4.7 Detective measures, such as technologies that provide real-time monitoring and alerting, should be instituted to provide visibility of the usage and performance of APIs, and detect suspicious activities. Robust measures should be established to promptly revoke the API keys or access token in the event of a breach.

¹⁰ An access token contains credentials that are used to validate the requestor and ensure the requestor has the permissions to access the requested data or perform the requested operations.

6.4.8 The FI should ensure adequate system capacity is in place to handle high volumes of API call requests, and implement measures to mitigate cyber threats such as denial of service (DoS) attacks.

6.5 Management of End User Computing and Applications

6.5.1 The prevalence of business application tools and software on the Internet has enabled end user computing, where business users develop or use simple applications to automate their operations, such as performing data analysis and generating reports. IT hardware, software and services that are not managed by the IT department (shadow IT) increase the FI's exposure to risks such as leakage of sensitive data or malware infection. Shadow IT should be managed as part of the FI's information assets.

6.5.2 The FI should establish measures to control and monitor the use of shadow IT in its environment.

6.5.3 A process should be established to assess the risk of end user developed or acquired applications to the FI, and ensure appropriate controls and security measures are implemented to address the identified risks, and approval is obtained before being used. The FI should ensure proper testing before the applications are deployed.

7 IT Service Management

7.1 IT Service Management Framework

7.1.1 A robust IT service management framework is essential for supporting IT services and operations, tracking information assets, managing changes, responding to incidents, as well as ensuring the stability of the production IT environment. The framework should comprise the governance structure, processes and procedures for IT service management activities including configuration management, technology refresh management, patch management, change management, software release management, incident management and problem management.

7.2 Configuration Management

7.2.1 Configuration management is the process of maintaining key information (e.g. model, version, specifications, etc.) about the configuration of the hardware and software that makes up each IT system. The FI should implement a configuration management process to maintain accurate information of its hardware and software to have visibility and effective control of its IT systems.

7.2.2 The FI should review and verify the configuration information of its hardware and software on a regular basis to ensure it is accurate and up-to-date.

7.3 Technology Refresh Management

7.3.1 The FI should avoid using outdated and unsupported hardware or software, which could increase its exposure to security and stability risks. The FI should closely monitor the hardware's or software's end-of-support (EOS) dates as service providers would typically cease the provision of patches, including those relating to security vulnerabilities that are found after the EOS date.

7.3.2 A technology refresh plan for the replacement of hardware and software should be developed before they reach EOS. A risk assessment for hardware and software approaching EOS date should be conducted to evaluate the risks of their continued use, and effective risk mitigation measures should be implemented.

7.3.3 The FI should obtain dispensation from its management for the continued use of outdated and unsupported hardware and software. The dispensation should be assigned a validity period that is commensurate with the identified risks and risk mitigation measures. The dispensation should be reviewed periodically to ensure the attendant risks remain at an acceptable level.

7.4 Patch Management

7.4.1 A patch management process should be established to ensure applicable functional and non-functional patches (e.g. fixes for security vulnerabilities and software bugs) are implemented within a timeframe that is commensurate with the criticality of the patches and the FI's IT systems.

7.4.2 Patches should be tested before they are applied to the FI's IT systems in the production environment to ensure compatibility with existing IT systems or they do not introduce problems to the IT environment.

7.5 Change Management

7.5.1 The FI should establish a change management process to ensure changes to information assets are assessed, tested, reviewed and approved before implementation.

7.5.2 A risk and impact analysis of the change to an information asset should be conducted before implementing the change. The analysis should cover factors such as security and implications of the change in relation to other information assets.

7.5.3 The FI should ensure all changes are adequately tested in the test environment. Test plans for changes should be developed and approved by the relevant business and IT management. Test results should be accepted and signed off before the changes are deployed to the production environment.

7.5.4 A change advisory board, comprising key stakeholders including business and IT management, should be formed to approve and prioritise the changes after considering the stability and security implications of the changes to the production environment.

7.5.5 The FI should perform a backup of the information asset prior to the change implementation, and establish a rollback plan to revert the information asset to the previous state if a problem arises during or after the change implementation.

7.5.6 Urgent or emergency changes, such as a high priority security patch for an IT system, are changes that need to be implemented expeditiously and may not be able to follow the standard change management process. To reduce the risk to the security and stability of the production environment, the FI should clearly define the procedures for assessing, approving and implementing emergency changes, as well as identify the authorisers or approvers for the changes.

7.5.7 Logs contain useful information which facilitates investigations and troubleshooting. As such, the FI should ensure the logging facility is enabled to record activities that are performed during the change process.

7.6 Software Release Management

7.6.1 Segregation of duties in the software release process should be practised to ensure no single individual has the ability to develop, compile and move software codes¹¹ from one environment to another.

7.6.2 It is important that controls are implemented to maintain traceability and integrity for all software codes that are moved between IT environments.

7.7 Incident Management

7.7.1 An IT incident occurs when there is an unexpected disruption to the delivery of IT services or a security breach of an IT system, which compromises the confidentiality, integrity and availability of data or the IT system. The FI should establish an incident management framework with the objective of restoring an affected IT service or system to a secure and stable state, as quickly as possible, so as to minimise impact to the FI's business and customers.

7.7.2 The FI should ensure sufficient resources are available to facilitate and support incident response and recovery. The FI may engage external assistance to augment its resources to facilitate and support incident response and recovery. For example, the FI can engage an incident response and security forensic company to support cyber attack investigation, and provide 24 by 7 incident response capability.

¹¹ Source codes, byte codes and binaries

7.7.3 The incident management framework should minimally cover:

- (a) the process and procedure for handling IT incidents, including cyber related incidents;¹²
- (b) maintenance and protection of supporting evidence for the investigation and diagnosis of incidents; and
- (c) the roles and responsibilities of staff and external parties involved in recording, analysis, escalation, decision-making, resolution and monitoring of incidents.

7.7.4 The FI should configure system events or alerts to provide an early indication of issues that may affect its IT systems' performance and security. System events or alerts should be actively monitored so that prompt measures can be taken to address the issues early.

7.7.5 In some situations, a major incident may develop unfavourably into a crisis. The FI should regularly apprise its senior management of the status of major incidents so that decisions to mitigate the impact of the crisis can be made in a timely manner, such as activation of IT disaster recovery.

7.7.6 A communications plan that covers the process and procedures to apprise customers of impact on services, and to handle media or public queries should be maintained. The plan should also include identifying the spokespersons and subject matter experts to address the media or public queries as well as the communication channels to disseminate information.

7.7.7 It would be useful for the FI to provide timely updates to its customers on the progress of its incident management and the measures the FI is implementing to protect its customers and continue delivery of financial services. Where appropriate, the FI should advise its customers on actions that they should take to protect themselves.

¹² Examples of cyber incidents include malware infection, social engineering, man-in-the-middle attack, denial of service attack, etc.

7.8 Problem Management

7.8.1 The FI should establish problem management process and procedures to determine and resolve the root cause of incidents to prevent the recurrence of similar incidents.

7.8.2 The FI should maintain a record of past incidents which include lessons learnt to facilitate the diagnosis and resolution of future incidents with similar characteristics.

7.8.3 A trend analysis of past incidents should be performed by the FI to identify commonalities and patterns in the incidents, and verify if the root causes to the problems had been properly identified and resolved. The FI should also use the analysis to determine if further corrective or preventive measures are necessary.

8 IT Resilience

8.1 System Availability

8.1.1 Maintaining system availability is crucial in achieving confidence and trust in the FI's operational capabilities. IT systems should be designed and implemented to achieve the level of system availability that is commensurate with its business needs.

8.1.2 Redundancy or fault-tolerant solutions should be implemented for IT systems which require high system availability. The FI should perform a periodic review of its IT system and network architecture design to identify weaknesses in the existing design. The review should include a mapping of internal and external dependencies of the FI's IT systems to determine any single point of failure. It is important that the FI conducts regular testing to ascertain that the level of resilience continues to meet its business requirements.

8.1.3 The FI should continuously monitor the utilisation of its system resources against a set of pre-defined thresholds.¹³ Such monitoring could facilitate the FI in carrying out capacity management to ensure IT resources are adequate to meet current and future business needs.

8.1.4 Procedures should be established to respond to situations when pre-defined thresholds for system resources and system performance have been breached.

8.2 System Recoverability

8.2.1 The FI should establish systems' recovery time objectives (RTO) and recovery point objectives (RPO) that are aligned to its business resumption and system recovery priorities.

8.2.2 The FI's disaster recovery plan should include procedures to recover systems from various disaster scenarios, as well as the roles and responsibilities of relevant personnel in the recovery process. The disaster recovery plan should be reviewed at least

¹³ The monitoring of system resources could cover the utilisation of the computing processor, memory and data storage. For network resources, the monitoring indicators could cover network throughput, latency and packet loss.

annually and updated when there are material changes to business operations, information assets or environmental factors.

8.2.3 During the recovery process, the FI should follow the established disaster recovery plan that has been tested and approved by management. The FI should avoid deviating from the plan as untested recovery measures could exacerbate the incident and prolong the recovery process. In exceptional circumstances where untested recovery measures need to be used, the FI should perform a risk assessment and ensure adequate controls are in place, as well as obtain approval from senior management.

8.2.4 The FI should endeavour to operate from its recovery, secondary or alternate site periodically so as to have the assurance that its infrastructure and systems at these sites are able to support business needs for an extended period of time when production systems failover from the primary or production site.

8.3 Testing of Disaster Recovery Plan

8.3.1 The FI should perform regular testing of its disaster recovery plan to validate the effectiveness of the plan and ensure its systems are able to meet the defined recovery objectives. Relevant stakeholders, including those in business and IT functions, should participate in the disaster recovery test to familiarise themselves with the recovery processes and ascertain if the systems are performing as expected.

8.3.2 A disaster recovery test plan should include the test objectives and scope, test scenarios, test scripts with details of the activities to be performed during and after testing, system recovery procedures, and the criteria for measuring the success of the test.

8.3.3 The testing of disaster recovery plan should comprise:

- (a) various plausible disruption scenarios, including full and partial incapacitation of the primary or production site and major system failures; and
- (b) recovery dependencies between information assets, including those managed by third parties.

8.3.4 Where information assets are managed by service providers, the FI should assess the service provider's disaster recovery capability and ensure disaster recovery arrangements for these information assets are established, tested and verified to meet its